SciWell® 天津市科远系统工程有限公司
TIANJIN KEYUAN SYSTEM ENGINEERING CO., LTD.

天津市科远系统工程有限公司

信息安全管理程序

文件编号	SciWell-ITSS-YW-1508	版本	V1.1
作者	王宇昊	编写日期	2025-01-05
审核	侯永平	审核日期	2025-01-06
批准	赵洁	批准日期	2025-01-06
发布范围	内　部	发布日期	2025-01-07

文档修订信息

版本号	修订日期	修订人	修订说明	备注
V1.0	2022-01-05	王宇昊	新建	
V1.1	2025-01-05	王宇昊	制度调整	

目 录

1 目的 1
2 过程定义 1
2.1 范围 1
2.2 过程负责人 1
2.3 主要输入 2
2.4 主要输出 2
2.5 角色和职责权限 2
2.6 过程重要控制点 3
3 术语 3
4 安全方针 3
5 流程 4
6 过程描述 4
6.1 需求识别和分析 5
6.2 确定安全实施范围 5
6.3 信息安全风险评估 5
6.4 设计安全规范 5
6.5 实施安全规范 5
6.6 监控安全状况 6
6.7 维护安全规范 6
6.8 信息安全报告 6
7 关键绩效指标（KPI） 7
8 相关文件 7
9 输出的文件及记录 7

1 目的

本制度旨在对天津市科远系统工程有限公司（以下简称“公司”）执行信息安全风险评估提供指导和规范。

本制度的目的是在运维服务工作中有效管理信息安全。

- 满足软件产品及项目运行和运维服务中的安全性需求以及合同、法律和外部政策等外部要求；
- 提供一个满足需求的基本的信息系统安全基线；
- 确保有效的信息安全措施在管理层、运维服务部门和运维人员三个层面都得到贯彻。

2 过程定义

安全管理是顺应信息安全的需要而产生的，其主要目标是确保信息的安全性。

安全管理致力于确保服务的安全性在任何时候都能达到与客户约定的级别。

安全性在服务中被视为可用性管理的一部分。安全管理已经成为现代服务管理中一个重要的问题。

安全性是指不易遭到已知风险的侵袭，并且尽可能地规避未知风险的性能。提供这种性能的工具是安全措施。

安全措施的目标是要保护信息的价值，这种价值取决于机密性、完整性和可用性三个方面。

2.1 范围

本制度适用于运维服务覆盖的所有部门。

2.2 过程负责人

技术部负责人

2.3 主要输入

输入	来源
服务级别需求	服务级别协议
配置管理	系统的配置项，记录和报告配置

2.4 主要输出

输出	去向
风险评估报告	信息安全管理负责人、部门经理、钉盘
信息安全规范	信息安全管理负责人、部门经理、钉盘
变更管理	服务实施过程中，服务交付过程的主要步骤。
服务报告管理	服务实施过程中，服务交付过程的主要步骤。

2.5 角色和职责权限

2.5.1 技术部经理（安全管理负责人）

1) 负责本制度的制订、修改与管理；

2) 确定每次信息安全风险评估的范围，组建信息安全风险评估工作组；

3) 负责批准信息安全风险评估报告；

4) 负责整个安全管理流程的有效运作；

5) 监控安全管理流程。

2.5.2 技术部项目经理（信息安全服务负责人）

1) 根据组织安全需求，开发与维护安全计划；

2) 处理与安全相关的问题和事件；

3) 确保满足 SLA 中指定的安全需求；

4) 负责安排项目中的信息安全风险评估；

5) 做好用户的沟通，协调关于信息安全的问题；

6) 完成包含流程结果，自评估及内部审计的信息安全风险评估报告。

2.6 过程重要控制点

风险评估报告

信息安全管理规范

安全事件记录

3 术语

- **机密性：**指保护信息免受未经授权的访问和使用。
- **完整性：**指信息的准确性、完全性和及时性。
- **可用性：**是信息在任何约定的时间内都可以被访问。这取决于由信息处理系统所提供的持续性

4 安全方针

遵循公司“统一规划、分级管理、积极防范、人人有责”的原则，按照公司统一部署，结合服务/经营活动的特点，采取一切必要的措施，加强信息安全体系的建设和推进管理。

5 流程

6 过程描述

信息安全活动划分为三个部分，包括规划、实施和监控。规划包括需求识别和分析、确定安全实施范围、信息安全风险评估、安全规范设计；实施包括安全规范实施；监控包括安全状况监控、维护安全规范、信息安全报告。

6.1 需求识别和分析

根据服务级别协议中签订的关于安全的详细说明，确定安全需求并进行分析。服务级别协议中应该定义安全需求，在可能的情况下还应该以可测度的术语进行定义。该协议的安全部分应当确保客户所有的安全需求和标准能够实现，并且实现的结果能够进行明确的验证。需求识别的范围包括人员安全、数据安全、机房环境、设备安全、系统安全等的安全需求。

6.2 确定安全实施范围

根据安全需求的识别情况确定安全实施范围。安全实施范围包括列为相应安全等级的数据、人员、机房、设备、系统等。

6.3 信息安全风险评估

服务管理人员根据确定的安全实施范围进行风险分析与评估工作，并提交风险分析与评估报告。

风险评估包括识别安全实施范围内的资产状况、资产面临的威胁，现在使用的技术方法和管理规范，并进行总体分析得出风险的等级，编制《风险评估报告》。

6.4 设计安全规范

根据《风险评估报告》，服务负责人制定和编写《信息安全管理规范》。并根据信息安全规范制定信息安全策略、针对个人的保密协议、岗位职责说明等。

6.5 实施安全规范

在设计好安全规范后，日常需按照安全规范来实施安全管理。

1) 在人员安全方面的实施：
   - 职位说明中的任务和职责；
   - 安全防护；
   - 针对个人的保密协议；
2) 责任划分的实施，以及岗位分离的实施；
3) 书面的操作指示，内部规章；

4) 安全问题涉及整个生命周期，应针对系统开发、测试、验收、运营、维护和终止制定安全指南；

5) 将开发和测试环境与实际的运营环境分离开来；

6) 处理事件的程序（由事件管理负责人处理）；

7) 恢复设施的实施；

8) 为变更管理提供信息输入，病毒防护措施的实施；

9) 针对计算机、操作系统、应用系统、数据、网络和网络服务的安全管理措施的实施；

10) 数据媒介的处理和安全；

6.6 监控安全状况

对安全规范实施进行监控，在工作周报、服务月报中体现。

对发生的信息安全事件按照《事件管理程序》执行。

6.7 维护安全规范

服务管理人员根据系统运行及运维服务的风险变化，必要时对《信息安全管理规范》进行修改

由于基础架构、组织和业务流程方面的变化导致相关的风险也随着发生变化，因此安全也需要进行维护。

安全维护包括服务级别协议中安全部分的维护以及详细的安全规范的维护。

维护需要根据评估的结果以及对风险变化的评估结果进行。这些建议既可以直接被采纳，也可以纳入总体的服务级别协议的维护中。

安全规范更新通过变更管理实施,参照《变更管理程序》

6.8 信息安全报告

信息安全管理负责人根据信息安全管理的实施状况及日常发生的安全事件等，每月一次巡检，编写《信息安全服务报告》。

报告可以提供有关已实现安全绩效方面的信息，并可以了解有关的安全问题。

正确地了解有关努力（如安全措施的实施）所取得的效率以及实际被

采用的安全措施。

还需要了解所有的安全事件。为报告服务级别协议中定义的安全事件，可通过服务级别管理负责人、事件管理负责人或安全管理负责人与部门经理直接的沟通渠道。

除了在特殊情形下的例外事项，报告都是通过服务级别管理负责人进行传达的。

根据信息安全管理需要报告信息安全的实施情况，并提交给《服务报告》中，参照《服务报告管理程序》。

7 关键绩效指标（KPI）

绩效指标	目标值	衡量方式	考核频度	责任部门
信息安全事故数量	=0 次	我方人员造成信息安全事故的次数	月度	技术部

8 相关文件

《服务报告管理程序》

《事件管理程序》

《变更管理程序》

9 输出的文件及记录

文件及记录	责任人
《信息资产清单》	技术部
《信息资产脆弱性和威胁表》	技术部
《信息资产风险评估表》	技术部
《风险处置计划表》	技术部
《残余风险报告》	技术部